KABITA

Mengamankan backend
pencatatan
berat badan & pakan kambing.

Lab tertutup tiga node: satu replika backend IoT yang sengaja dibuat rentan, satu penyerang, satu sensor — lalu satu siklus tertutup sampai celahnya benar-benar tertutup.

Lead
Olan Elrai R. Sibagariang
J0404241158

Blue Team
Anggi Permana Putra
J0404241154

Red Team
Raka S. Ferdian · J0404241112
Muhammad Zidan · J0404241173

YANG KAMI AMANKAN

Peternakan mencatat angka.
Kalau angkanya dipalsukan, keputusan ikut salah.

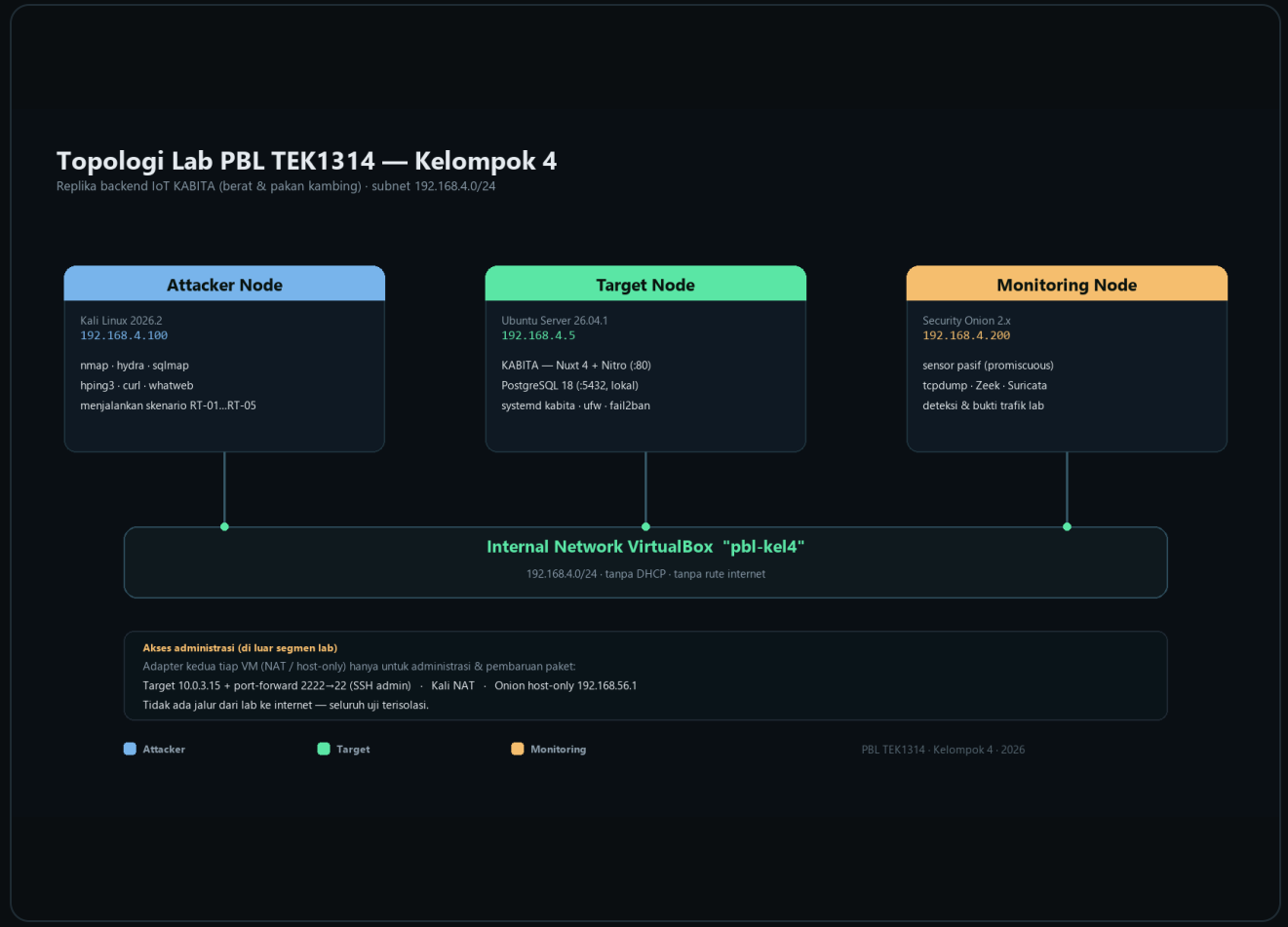
2 kandang	**Kandang A pejantan, Kandang B indukan.** Setiap kambing punya identitas RFID; pencatatan dilakukan per ekor, bukan per kandang.
6 kambing	**Berat dan pakan dicatat bersamaan.** Satu baris telemetri = satu penimbangan plus jumlah pakan yang diberikan hari itu.
60 catatan	**Sepuluh hari riwayat.** Cukup untuk membedakan traffic normal dari traffic serangan saat evaluasi deteksi.
3 node	**Penyerang, target, sensor.** Semua di satu jaringan internal tanpa akses internet, sehingga hasil uji bisa diulang persis.

TOPOLOGI

192.168.4.0/24 — tiga node, tanpa jalan keluar.

- 192.168.4.100 — Kali 2026.2
  nmap · hydra · sqlmap · hping3
- 192.168.4.5 — Ubuntu Server 26.04.1
  KABITA Nuxt 4 di :80 · PostgreSQL 18 di :5432
- 192.168.4.200 — Security Onion 2.x
  sensor pasif, promiscuous

Adapter kedua hanya untuk administrasi: SSH 2222→22 di target, NAT di Kali, host-only di sensor.



TECH STACK

Satu proses aplikasi, satu basis data, satu unit systemd.

APLIKASI	**Nuxt 4 + Nitro** — SSR dan API dalam satu proses	`:80`
RUNTIME	**Node.js 22** — dijalankan systemd, bukan root	`kabita.service`
BASIS DATA	**PostgreSQL 18** — 5 tabel, 60 baris telemetri	`:5432 lokal`
PERLINDUNGAN	**ufw + fail2ban** — default deny, jail sshd	`Fase 1`
TANPA	**nginx, broker MQTT, container** — lebih sedikit lapisan, lebih sedikit celah	`keputusan`

Ingest meniru perangkat: `POST /api/telemetri?token=…` dengan body `{rfid, berat_kg, pakan_kg}`.

RANCANGAN YANG DISENGAJA

Enam celah dibiarkan hidup — supaya penutupannya bisa dibuktikan.

	CELAH	DIUJI OLEH	DITUTUP OLEH
1	SQL injection pada `/api/telemetri` & `/api/login`	RT-03	C-2
2	Password plaintext, kredensial `admin/admin123`	RT-02, RT-03	A-1, C-2
3	Token device statis, dikirim lewat query string	RT-03	C-3
4	Telemetri tanpa validasi rentang nilai	RT-03	C-3
5	Cookie sesi tanpa tanda tangan	RT-04	A-1, C-1
6	SSH masih memakai password; tanpa TLS di :80	RT-02, RT-01	A-2, C-1

FASE 1 — HASIL

Tiga kontrol berjalan, tanpa memutus layanan.

B-1 · service	B-2 · firewall	B-3 · patch	A & C
24 → 18 service	default deny	10 paket phased	7 kontrol → Fase 2

482

paket baseline dalam 50 detik: 452 di port 80, 45 koneksi baru, 30 ICMP. Angka inilah pembanding saat serangan berlangsung.

Dashboard tetap **HTTP 200** setelah firewall aktif — hardening tidak memutus layanan. Uji dilakukan dari penyerang, bukan dari server sendiri.

FASE 2 — RENCANA

Lima skenario, satu DoS, semuanya ditutup.

RT-01	Discovery	nmap -sV & whatweb: memetakan 22/80 dan memastikan 5432 tidak terekspos
RT-02	Kredensial SSH	hydra dengan wordlist kecil; fail2ban harus mencatat kegagalan
RT-03	SQL injection	auth bypass login, dump telemetri, lalu telemetri palsu masuk dashboard
RT-04	Pemalsuan sesi	cookie `kabita_user` dipalsukan → dashboard terbuka tanpa login
RT-05	DoS terkontrol	30 detik SYN flood ke :80, ukur waktu pemulihan — bukan dampak

SERANG — DETEKSI — ANALISIS — MITIGASI — UJI ULANG satu siklus tuntas sebelum skenario berikutnya

POSISI SEKARANG

Lab hidup, bukti tersimpan, serangan belum dijalankan.

SELESAI	Lab 3 node · replika KABITA · baseline · hardening awal	Fase 1
BERJALAN	Sensor Onion: verifikasi cakupan & aturan deteksi	Minggu 10
BERIKUTNYA	Eksekusi RT-01…RT-05, isi lima tahap, tutup tujuh kontrol	Minggu 10–11

REPOSITORI

github.com/anggi267/TEK1314-2026-Kel04-KelasA

Semua angka di deck ini berasal dari keluaran perintah di lab, bukan perkiraan.